



JURUTERA SIBER RAMSEC
JURUS

KAEDAH PENILAIAN DAN RUBRIK PERTANDINGAN

Dr Mohd Najwadi Yusoff
Universiti Sains Malaysia



PENGENALAN

JURUS (Jurutera Siber rawSEC) ialah program laluan kompetensi keselamatan siber kebangsaan di Malaysia.

Program ini dibangunkan oleh komuniti rawSEC dengan kerjasama strategik Cybersecurity Research Centre (CYRES), Universiti Sains Malaysia (USM).

Ia berfungsi sebagai projek rintis (pilot project) nasional untuk melatih dan menguji generasi baharu pakar keselamatan siber tempatan.

Latihan **merangkumi aspek pertahanan sistem asas sehinggalah ke tahap seni bina ketahanan infrastruktur.**

KOMPONEN PENILAIAN JURUS

Laporan – 50%

Pembentangan / Live Demo – 50%

Markah Lulus = **70%**

KAJIAN KES

Municipal Citizen Service Portal Project

Digital Transformation: MP Cyberjaya is **launching a one-stop Citizen Service Portal** for resident complaints, requests, tracking, and announcements.

The Audit Gap: An **external audit revealed that the council lacks the secure, operational infrastructure required to back this service.**

Your Role: Acting as a Cyber Engineering Consultancy (Lead Analyst) to **design and deliver a production-ready environment.**

No infrastructure, tools, or templates are provided. Participants must independently determine technologies using sound engineering judgment.

KAJIAN KES (SAMB.)

Timeline & Engineering Execution

Challenge Duration: **Three (3) weeks total to design, build, and deploy.**

Deployment Flexibility: Complete freedom to use local virtualization (VMs), cloud environments, or bare-metal physical hardware.

Participants are fully responsible for:

- Infrastructure provisioning and software installation.
- Security configuration, baseline auditing, and system testing.
- Hands-on troubleshooting, logging verification, and live demo preparation.

KAJIAN KES (SAMB.)

Technical Deliverables & Grading Policy

Comprehensive Technical Package / Report (50% of Marks):

- Solution architecture diagram and technical implementation blueprints.
- Hardening evidence, configurations, validation results, scripts, and logs.

Engineering-First Philosophy:

- Assessment evaluates demonstrated capability rather than theoretical knowledge.
- Heavy emphasis is placed on solutions that are appropriate, secure, maintainable, and clearly documented.

KAJIAN KES (SAMB.)

Live Demo & Technical Defense Session

Time Allocation: **Strictly 30 minutes per participant.** Contribute another **50% of Marks.**

Presentation & Rationale: Present the architecture and justify technology selections, trade-offs, and risk mitigation strategies.

Live Pressure Test: Assessors may request live, on-the-spot demonstrations of administrative controls, database defenses, or backup recovery execution.

CADANGAN SOLUSI

Kejuruteraan Sistem & Rangkaian (OS & Network Hardening)

Sistem Operasi: Linux Ubuntu Server 24.04 LTS atau Linux Mint (Virtual Machine dalam VMware/Proxmox).

Kawalan Akses & SSH:

- **Matikan login root secara terus** (PermitRootLogin no).
- **Wajibkan pengesahan berasaskan kunci awam** (Key-based Authentication) sahaja. Tukar port default SSH (contoh: port 2222).

Host Firewall (ufw): Set polisi default untuk menyekat semua trafik masuk (sudo ufw default deny incoming). **Hanya buka port web** (HTTP/HTTPS) **dan port SSH** tersuai secara bersasar.

CADANGAN SOLUSI (SAMB.)

Keselamatan Aplikasi (Application Security)

Web Server / Reverse Proxy: Nginx.

Hardening Lapisan Web:

- **Sembunyikan banner versi perisian** (server_tokens off; dalam Nginx).
- Konfigurasi SSL/TLS menggunakan sijil self-signed atau Let's Encrypt (dengan TLS 1.3 sahaja, matikan protokol usang seperti TLS 1.0/1.1).
- Masukkan pengepala keselamatan (Security Headers) seperti X-Frame-Options, Content-Security-Policy, dan X-Content-Type-Options.

CADANGAN SOLUSI (SAMB.)

Keselamatan Pangkalan Data (Database Security)

Teknologi: PostgreSQL atau MariaDB.

Hardening Pangkalan Data:

- Least Privilege: Cipta pengguna (user) **khusus untuk portal web dengan hak akses terhad** (hanya SELECT, INSERT, UPDATE pada jadual tertentu). Jangan sekali-kali gunakan akaun root atau postgres dalam kod aplikasi.
- Host Access Management: Konfigurasi fail pg_hba.conf atau my.cnf supaya pangkalan data hanya menerima sambungan daripada hos tempatan (localhost / standard Unix socket), bukan daripada IP luar.

CADANGAN SOLUSI (SAMB.)

Pemantauan Keselamatan (Security Monitoring / Observability)

Fail2ban: Dipasang untuk memantau log SSH dan Nginx. **Jika terdapat cubaan log masuk gagal melebihi 5 kali, IP tersebut akan disekat** (banned) secara automatik melalui iptables.

Log Management: Gunakan Rsyslog atau Logwatch untuk mengumpulkan log sistem yang kritikal, diletakkan di bawah pengawasan ketat dengan konfigurasi log rotation yang selamat.

CADANGAN SOLUSI (SAMB.)

Business Continuity & Recovery (BCP/DR)

Automated Backup: Sediakan **skrip Bash (backup.sh)** yang dijalankan secara **automatik** menggunakan Cron Job.

Mekanisme: Skrip akan melakukan database dump (pg_dump atau mysqldump), memampatkan fail fail aduan warga, dan menyimpannya ke direktori sandaran tersendiri lengkap dengan tanda masa (timestamp).

Pengukuran Parameter: **Simulasikan pemulihan untuk mengira masa bertindak secara nyata** bagi mematuhi had RTO (Recovery Time Objective) dan RPO (Recovery Point Objective).

CADANGAN MAKLUMAT DALAM LAPORAN

1. Executive Summary & Architecture: Gambar rajah topologi rangkaian logikal, huraian persekitaran (VM/Cloud), spesifikasi perkakasan dan justifikasi pemilihan OS - **Diagram dan Teks.**
2. Operating System & Network: Bukti konfigurasi pelayan, polisi sudoers, pengerasan SSH Daemon, dan rantai peraturan Firewall (UFW/Iptables) – **Fail konfigurasi dan kod bash**
3. App & Database Lockdown: Kebenaran fail konfigurasi pangkalan data, bukti sekatan akses port DB, tetapan SSL/TLS Nginx, dan laporan ujian tajuk HTTP – **Screenshot dan Kod Konfigurasi**
4. Logging & Alerting System: Konfigurasi pemantau log (Syslog/Wazuh/Fail2ban) dan log amaran aktif yang memaparkan cubaan serangan dikesan secara langsung – **Ekstrak Fail Log.**
5. BCP/DR Strategy & Scripts: Kod skrip sandaran automatik, kunci enkripsi, dan pembuktian langkah pemulihan (restore) pangkalan data berpandukan parameter RTO/RPO – **Skrip bash dan jadual RTO**

30 MINIT PEMBENTANGAN

1. Minit 0–7 (Seni Bina & Rationale): **Bentangkan rajah infrastruktur anda**. Nyatakan mengapa teknologi tersebut dipilih dan apa trade-off yang anda ambil (Contoh: memilih persekitaran tunggal atas faktor kawalan kos dan kekangan masa 3 minggu).
2. Minit 8–20 (Live Pressure Test / Walkthrough): Tunjukkan bukti sistem berfungsi secara langsung di hadapan penilai: **Lakukan vulnerability scanning ringkas untuk membuktikan banner versi pelayan berjaya disembunyikan**. Tunjukkan log iptables/ufw yang menapis trafik masuk. Pamerkan akaun pangkalan data yang tidak boleh mengakses jadual sistem lain.
3. Minit 21–25 (Simulasi BCP/DR): **Jalankan skrip backup anda secara langsung**, padamkan pangkalan data secara sengaja (simulated crash), dan lakukan proses restore (pemulihan) untuk membuktikan sistem kembali normal dalam tempoh RTO yang ditetapkan.
4. Minit 26–30 (Sesi Soal Jawab / Technical Defense): **Bersedia mempertahankan reka bentuk anda** daripada soalan kritikal penilai mengenai pengurusan risiko siber portal tersebut.

RUBRIK PENILAIAN

Laporan – 50%

Modul 1: Kejuruteraan Sistem Operasi (OS Engineering) – 10%

Modul 2: Keselamatan Rangkaian (Network Security) – 10%

Modul 3: Keselamatan Pangkalan Data (DB Security) – 10%

Modul 4: Keselamatan Aplikasi (Application Security) – 10%

Modul 5: Pemantauan Keselamatan (Security Monitoring) – 5%

Modul 6: Perancangan Kesyinambungan Perniagaan (BCP) – 5%

RUBRIK PENILAIAN (SAMB.)

Contoh

Item Penilaian	Lemah	Kurang Memuaskan	Memuaskan	Baik	Cemerlang
	Skor (0 - 2)	Skor (3 - 4)	Skor (5 - 6)	Skor (7 - 8)	Skor (9 - 10)
Modul 1: Kejuruteraan Sistem Operasi (OS Engineering) Fokus: Pembinaan kerangka asas dan konfigurasi hos yang selamat. Kriteria: Pengurusan pengguna (user privileges/sudo), polisi kata laluan, penutupan port/perkhidmatan yang tidak digunakan, dan konfigurasi asas firewall hos.	Tiada usaha hardening dilakukan pada OS. Sistem dibiarkan dalam keadaan lalai yang tidak selamat atau laporan gagal menunjukkan bukti konfigurasi OS.	Pemasangan OS dilakukan tetapi langkah pengerasan (hardening) sangat minima. Banyak port terbuka dan tiada polisi keselamatan asas diwujudkan pada sistem operasi.	OS berfungsi dengan konfigurasi keselamatan tahap asas. Firewall dihidupkan, tetapi kawalan pengguna (seperti akses sudo) masih terlalu longgar atau menggunakan tetapan lalai (default).	Hos berjaya dikonfigurasi dengan selamat dan port yang tidak digunakan ditutup. Walau bagaimanapun, terdapat sedikit kelemahan minor (contohnya: polisi jangka hayat kata laluan belum diaktifkan sepenuhnya).	Hos dibangunkan dengan kawalan akses yang ketat (tiada root login terus, konfigurasi sudo terhad), polisi kata laluan kompleks diaktifkan, servis yang tidak digunakan dimatikan sepenuhnya, dan firewall hos dikonfigurasi dengan tepat. Bukti dokumentasi lengkap dan bebas ralat.

RUBRIK PENILAIAN

Laporan – 50%

Modul 1: Kejuruteraan Sistem Operasi (OS Engineering) – 10%

Modul 2: Keselamatan Rangkaian (Network Security) – 10%

Modul 3: Keselamatan Pangkalan Data (DB Security) – 10%

Modul 4: Keselamatan Aplikasi (Application Security) – 10%

Modul 5: Pemantauan Keselamatan (Security Monitoring) – 5%

Modul 6: Perancangan Kesyinambungan Perniagaan (BCP) – 5%

RUBRIK PENILAIAN (SAMB.)

Pembentangan / Live Demo – 50%

Item 1: Demo Langsung dan Sesi Panduan ("Live-Demo" & Walkthrough) – 15%

Item 2: Justifikasi Audit Pengerasan (Audit Hardening Justification) – 15%

Item 3: Kefahaman Parameter Kelangsungan Perniagaan (Pengukuran MTD, MTO, RTO, RPO) – 10%

Item 4: Keupayaan Menjawab Soalan Interaktif (Q&A Session) – 10%

RUBRIK PENILAIAN (SAMB.)

Contoh

Item Penilaian	Lemah	Kurang Memuaskan	Memuaskan	Baik	Cemerlang
	Skor (0 - 2)	Skor (3 - 4)	Skor (5 - 6)	Skor (7 - 8)	Skor (9 - 10)
Item 1: Demo Langsung dan Sesi Panduan ("Live-Demo" & Walkthrough) Fokus: Pengesahan fungsi sistem secara masa nyata (real-time) merentasi kesemua 6 modul (OS, Rangkaian, DB, Aplikasi, Pemantauan, BCP/DR) bagi membuktikan sistem beroperasi dengan selamat dan dibangunkan secara individu.	Gagal menunjukkan demo langsung bagi sebahagian besar modul, sistem tidak berfungsi, atau bukti walkthrough langsung tidak relevan dengan 6 modul yang ditetapkan.	Hanya berjaya mendemonstrasikan 3 modul atau kurang secara langsung. Sesi demo berhadapan dengan banyak ralat kritikal, dan calon kelihatan tidak mahir mengendalikan persekitaran sistem bagi modul-modul lain.	Hanya berjaya mendemonstrasikan 4 hingga 5 modul secara langsung dengan lancar. Modul yang berbaki mengalami masalah teknikal semasa demo tetapi calon masih boleh membuktikan kewujudan konfigurasinya melalui semakan fail konfigurasi di terminal.	Berjaya mendemonstrasikan kesemua 6 modul, namun terdapat ralat kecil atau gangguan teknikal minor pada 1 atau 2 modul yang berjaya diatasi oleh calon dengan pantas tanpa menjejaskan fungsi utama.	Berjaya mendemonstrasikan fungsi keselamatan bagi kesemua 6 modul dengan lancar tanpa ralat. Langkah walkthrough pada terminal/sistem sangat tersusun dan membuktikan penguasaan penuh secara mandiri bagi setiap modul.

RUBRIK PENILAIAN (SAMB.)

Pembentangan / Live Demo – 50%

Item 1: Demo Langsung dan Sesi Panduan ("Live-Demo" & Walkthrough) – 15%

Item 2: Justifikasi Audit Pengerasan (Audit Hardening Justification) – 15%

Item 3: Kefahaman Parameter Kelangsungan Perniagaan (Pengukuran MTD, MTO, RTO, RPO) – 10%

Item 4: Keupayaan Menjawab Soalan Interaktif (Q&A Session) – 10%

CONTOH PENGIRAAN

Modul 1: Kejuruteraan Sistem Operasi (OS Engineering) – $10\% \times 0.7 = 7\%$

Modul 2: Keselamatan Rangkaian (Network Security) – $10\% \times 0.8 = 8\%$

Modul 3: Keselamatan Pangkalan Data (DB Security) – $10\% \times 0.8 = 8\%$

Modul 4: Keselamatan Aplikasi (Application Security) – $10\% \times 0.9 = 9\%$

Modul 5: Pemantauan Keselamatan (Security Monitoring) – $5\% \times 0.6 = 3\%$

Modul 6: Perancangan Kesenambungan Perniagaan (BCP) – $5\% \times 0.6 = 3\%$

Jumlah markah laporan = **38%**

CONTOH PENGIRAAN (SAMB.)

Item 1: Demo Langsung dan Sesi Panduan ("Live-Demo" & Walkthrough) – $15\% \times 0.8 = 12\%$

Item 2: Justifikasi Audit Pengerasan (Audit Hardening Justification) – $15\% \times 0.8 = 12\%$

Item 3: Kefahaman Parameter Kelangsungan Perniagaan (Pengukuran MTD, MTO, RTO, RPO) – $10\% \times 0.5 = 5\%$

Item 4: Keupayaan Menjawab Soalan Interaktif (Q&A Session) – $10\% \times 0.5 = 5\%$

Jumlah markah live demo = **34%**

Jumlah markah akhir = $38\% + 34\% = 72\%$

SESI SOAL JAWAB

Or email to: mentor@mcco.org.my